TLP:CLEAR | UNRESTRICTED DISTRIBUTION

CYBER THREAT INTELLIGENCE REPORT

FamousSparrow / SparrowDoor

Dynamic and Statics Analysis of a PRC-Attributed Loader Component with Geopolitical Strategic Assessment

Field	Value
Report ID	CTI-003 | SparrowDoor
Report Date	March 16, 2026
Analyst	SerapHim
Analyst Role	Independent Cyber Threat Intelligence
Sample SHA256	8dfaa1f579de14bca8bb27c54a57dd87646a835969766ca9ddb81ecd9329f4e4
Sample Filename	K7UI.dll (masquerading)
Threat Actor	FamousSparrow / Salt Typhoon / Earth Estries
Attribution	PRC -- HIGH confidence (external reporting)
Malware Family	SparrowDoor -- Legacy Variant (2019-2022)
Sample Source	ESET malware-ioc (github.com/eset/malware-ioc/famoussparrow)
Analysis Environment	isolated-CTI private switch, network-gapped
Analysis Tools	file, strings, objdump, Python3 Shannon entropy, Ghidra 10.4
TLP Classification	TLP:CLEAR -- Unrestricted Distribution
MITRE ATT&CK	T1574.002, T1027, T1055.001, T1562.001, T1140, T1059.003, T1071.001

1. Executive Summary

This report documents independent static and behavioral analysis of a FamousSparrow loader component (SHA256: 8dfaa1f579..., filename K7UI.dll), conducted in a network-isolated Parrot OS environment using file, strings, objdump, Python3 Shannon entropy calculation, and Ghidra 10.4. The sample was obtained from the ESET malware-ioc public repository. Technical findings are combined with external vendor intelligence and open-source geopolitical reporting to construct a strategic assessment of the campaign's intelligence objectives and trajectory.

Twenty technical findings (F1-F20) are documented from direct sample analysis. Four findings are not present in prior public vendor reporting at time of publication: an inverted anti-sandbox technique that terminates the process when no debugger is detected (F20), a three-table character substitution system for case-insensitive command processing without Windows API calls (F12-F15), anomalous .text section entropy indicating code obfuscation (F11), and an indirect call density of 113 FF 15 sites across a 26KB binary (F16). These are labeled [PHIM] throughout the report.

The sample corresponds to the legacy SparrowDoor variant (2019-2022) based on its single-stage loader architecture, basic reflective loading mechanism, and absence of parallelization capability. It functions as a Stage 1 component whose sole purpose is to load MpSvc.dll from disk into memory via reflective injection and transfer execution. No network capability, registry operations, or embedded C2 configuration are present in Stage 1.

The geopolitical assessment argues that FamousSparrow is not only a collection instrument. Read as a sequence, its targeting evolution -- hotels in MENA diplomatic zones (2019), Exchange servers via ProxyLogon (2021), US domestic ISPs and telecom providers (2023-2024) -- is documentary evidence of China's strategic reassessment of the Middle East: from a theater that could be contested, to one that had to be accepted as lost, and a repositioning of collection infrastructure for the scenario that follows. The 2023 pivot to US domestic telecommunications is not an escalation of the same operation. It is a change in the primary intelligence question being answered -- from monitoring normalization convergence speed to pre-positioning surveillance for a Taiwan Strait confrontation scenario.

2. Methodology

2.1 Scope and Objectives

This report set out to accomplish two objectives: (1) conduct independent static and behavioral analysis of a publicly available FamousSparrow sample to identify technical characteristics not documented in prior vendor reporting; and (2) correlate those findings with external vendor intelligence and open-source geopolitical data to construct a strategic assessment of the campaign's intelligence objectives and trajectory.

2.2 Secondary Analysis -- External Intelligence

External vendor intelligence sourced from ESET (2021, 2025), UK NCSC (2022), Trend Micro (2024), Trustwave SpiderLabs (2024), Microsoft, FBI, and CISA (2024). All claims are explicitly attributed and were not independently replicated by SerapHim. Geopolitical context sourced from Reuters, AP, WSJ, Modern Diplomacy, Arms Control Association, and The Silent Axis.

2.3 Confidence Level Scale

Level	Definition
HIGH	Supported by direct technical evidence or corroborated open source reporting
MODERATE	Supported by circumstantial evidence or pattern correlation
LOW	Inferred from limited indicators -- requires additional evidence to confirm

3. Technical Analysis

> *Findings F1-F20 represent original SerapHim analysis conducted directly against the sample. Findings marked [PHIM] were not documented in prior public vendor reporting at time of publication.*

3.1 Sample Identification

F1 -- PE Header

Attribute	Value
Type	PE32 executable, 32-bit DLL, Intel i386
Subsystem	Windows 5.00 (Windows 2000/XP era compatibility)
Sections	5 (.text, .rdata, .data, .rsrc, .reloc)

The binary is a 32-bit DLL compiled for Intel i386. The Windows 5.00 subsystem header is deliberate: it ensures the binary runs via WOW64 on all x64 Windows systems while reducing the likelihood of matching version-specific detection signatures built against modern PE headers. The 32-bit architecture provides maximum compatibility across heterogeneous victim environments, including hotel management systems, POS infrastructure, and legacy government deployments in secondary markets.

F2 -- DLL Sideloading via K7UI.dll Masquerade

Attribute	Value
Export name	K7UI.dll
Exported functions	K7UI_1, K7UI_13

The export table is fully falsified to claim the identity of a K7 Antivirus component. This is not merely a filename match -- the entire export table asserts K7 identity. When a system calls the legitimate K7UI, SparrowDoor answers. K7 Computing is a Chennai-based security vendor with primary market penetration in India, Southeast Asia, and parts of the Middle East. Masquerading as a K7 component positions this sample as an Asia/MENA-specific variant, developed further in Section 9.2. Security software operates with elevated trust and is unlikely to trigger suspicion when observed loading in an enterprise environment.

F3 -- MpSvc.dll Reference (Secondary Masquerade)

The string MpSvc.dll is present in the binary. MpSvc.dll is a Windows Defender Malware Protection service component. This represents a second layer of identity masquerade: K7 Antivirus at the export table level, Windows Defender at the string reference level. The C2 configuration and Stage 2 payload

are loaded from MpSvc.dll at runtime. The dual-masquerade architecture means any casual inspection encounters a plausible legitimate identity before reaching the malicious logic.

3.2 Obfuscation Mechanisms

F4 -- Character Substitution Tables (Static View)

Three lookup table variants are embedded in the binary:

```
Table 1: !"#$%&'()*+,-
./0123456789:;<=>?@ABCDEFGHIJKLMNOPQRSTUVWXYZ[\]^_`ABCDEFGHIJKLMNOPQRSTUVWXYZ{|}~
Table 2: !"#$%&'()*+,-
./0123456789:;<=>?@abcdefghijklmnopqrstuvwxyz[\]^_`abcdefghijklmnopqrstuvwxyz{|}~
Table 3: !"#$%&'()*+,-
./0123456789:;<=>?@ABCDEFGHIJKLMNOPQRSTUVWXYZ[\]^_`abcdefghijklmnopqrstuvwxyz{|}~
```

Strings with operational significance -- C2 addresses, registry paths, commands -- are not visible as plaintext. They are decoded at runtime using these tables. The substitution operates as a ROT/Caesar-style cipher with three variants covering different case transformation modes. Full address-level analysis is in F12-F15.

F12 -- Substitution Table Memory Addresses [PHIM]

Method: Ghidra Memory Search -- string !"#$%&, encoding US-ASCII, Search All.

```
10008898  -- Table variant 1 (Identity)
10008ea1  -- Table variant 2 (Uppercase-to-Lowercase)
10009021  -- Table variant 3 (Lowercase-to-Uppercase)
```

All three tables reside in .rdata (0x10008000-0x10009xxx). Byte-level confirmation at Table 1 base address:

```
10008898: 21h = '!'
10008899: 22h = '"'
1000889a: 23h = '#'
1000889b: 24h = '$'
1000889c: 25h = '%'
1000889d: 26h = '&'
```

F13 -- Table 1 (0x10008898): Identity Table [PHIM]

Range: 0x21 (!) through 0x7E (~). Each byte maps to itself -- no substitution occurs. This table functions as a passthrough baseline, used for validating that input is printable ASCII before processing by Tables 2 or 3. It is not an encoder.

F14 -- Table 2 (0x10008ea1): Uppercase-to-Lowercase Converter [PHIM]

```
Deviation begins at: 10008ec1 (offset 0x40 from table start)
0x41 'A' -> 0x61 'a'
0x42 'B' -> 0x62 'b'  ...  0x5A 'Z' -> 0x7A 'z'
Non-alpha range: identity (no change)
```

A pure case normalization table converting A-Z to a-z. Allows SparrowDoor to normalize C2 commands to lowercase before processing, enabling case-insensitive matching regardless of how the operator sends them. Critically, this is achieved without calling Windows API functions such as CompareStringA or

lstrcmpiA -- both would appear in the import table and are commonly flagged by security tooling. This is deliberate import-evasion engineering.

F15 -- Table 3 (0x10009021): Lowercase-to-Uppercase Converter [PHIM]

```
Deviation begins at: 10009061 (offset 0x40 from table start)
0x61 'a' -> 0x41 'A'
0x62 'b' -> 0x42 'B'  ...  0x7A 'z' -> 0x5A 'Z'
Non-alpha range: identity (no change)
```

The exact inverse of Table 2. Together, the three tables form a triplet normalization system: Table 1 for passthrough/validation, Table 2 for normalizing to lowercase, Table 3 for normalizing to uppercase. Bidirectional case-insensitive matching without any Windows string API call. No equivalent triplet system has been documented in ESET, UK NCSC, Trend Micro, or Microsoft FamousSparrow reporting.

3.3 Anti-Analysis Techniques

F5 -- IsDebuggerPresent Import

IsDebuggerPresent (KERNEL32.dll) is present in the import table. SparrowDoor actively detects whether it is executing inside a debugging environment. The full implementation and critical inversion of conventional anti-debug logic are documented in F20.

F20 -- DllMain Entry Point: Inverted Anti-Sandbox Logic [PHIM]

Method: Ghidra disassembly and decompilation of entry function at 100016a1.

Entry point flow (100016a1):

```
100016a6    CMP    dword ptr [EBP + param_2], 0x1    ; Check fdwReason ==
DLL_PROCESS_ATTACH
100016aa    JNZ    LAB_100016b1                       ; Skip if not
PROCESS_ATTACH
100016ac    CALL   FUN_10003c1d                       ; Main initialization
100016ba    CALL   FUN_100015ab                       ; Secondary initialization
```

Anti-sandbox logic (FUN_100016c4):

```
Phase 1 -- Environment detection:
1000177f    CALL   dword ptr [IsDebuggerPresent]     ; 0 = no debugger, 1 =
present
10001785    MOV    [DAT_1000ace8], EAX               ; Store result

Phase 3 -- Anti-sandbox termination logic:
100017a5    CMP    dword ptr [DAT_1000ace8], 0x0     ; Check IsDebuggerPresent
100017ac    JNZ    LAB_100017b6                      ; Debugger present: skip
termination
100017b6    PUSH   0xc0000409                        ;
STATUS_STACK_BUFFER_OVERRUN
100017bb    CALL   GetCurrentProcess
100017c2    CALL   TerminateProcess                  ; KILL THE PROCESS
```

CRITICAL FINDING -- Inverted Logic:

- Debugger detected (IsDebuggerPresent == 1): jump to LAB_100017b6, skip termination -- malware runs normally

- No debugger detected (IsDebuggerPresent == 0): fall through to TerminateProcess -- malware terminates immediately

This is not traditional anti-debug behavior, which terminates when a debugger is present. This is anti-sandbox behavior. Automated sandboxes (Cuckoo, ANY.RUN, Joe Sandbox) do not attach debuggers. IsDebuggerPresent returns 0 in those environments. SparrowDoor detects the absence of a debugger -- the standard sandbox condition -- and terminates. The sandbox logs a crash on startup and classifies the sample as non-functional. A human analyst working with a debugger attached proceeds normally.

The exception code 0xc0000409 (STATUS_STACK_BUFFER_OVERRUN) masquerades the deliberate termination as a triggered compiler security feature, not a malware self-kill. Two 32-bit cookie values are loaded into stack locals before the check: 0xBB40E64E and 0x44BF19B1 -- candidates for stack canaries or encryption keys.

Three hypotheses remain unresolved without dynamic analysis. Hypothesis A: FUN_100016c4 is operational anti-sandbox logic executing in production under specific initialization conditions. Hypothesis B: deliberate dead code designed to waste analyst time. Hypothesis C: conditional compilation artifact present in test builds to prevent sandbox submission, absent in production. Hypothesis A is most probable given the deliberate exception code masquerade.

CONFIDENCE: *MODERATE -- technique confirmed from disassembly. Operational function unresolved without dynamic analysis of live execution.*

3.4 Loader Architecture

F6 -- Minimal Import Profile (KERNEL32.dll Only)

Attribute	Value
Import count	1 DLL (KERNEL32.dll), approximately 60 functions
Notable absent	Winsock, WinHTTP, WinINet, Advapi32, Ws2_32

The absence of network, registry, and cryptographic library imports from the IAT is not an oversight. All advanced OS calls are loaded dynamically via LoadLibraryA + GetProcAddress at runtime. Static analysis tools and AV scanners that rely on import table inspection observe only the KERNEL32 footprint and draw no conclusions about network or registry capability.

F7 -- Reflective Loading Pattern

```
VirtualAlloc
VirtualProtect
ReadFile
GetProcAddress
LoadLibraryA
```

This combination is the classical signature for reflective DLL loading. MpSvc.dll is loaded from disk via CreateFileA + ReadFile, allocated to memory via VirtualAlloc, marked executable via VirtualProtect, and its exports resolved via manual PE parsing + GetProcAddress. Stage 2 operates entirely in memory and does not appear on disk as a standalone file during execution, defeating file-based AV scanning.

F16 -- Indirect Call Density: 113 FF 15 Sites [PHIM]

Attribute	Value
Method	Ghidra Memory Search -- Hex FF 15, Search All
Result	113 indirect call locations in .text section
Address range	10001042 - 100070df
Density	~1 indirect call per 230 bytes in a 26KB binary

FF 15 is the x86 opcode for CALL [mem] -- an indirect call through a pointer. 113 occurrences across a 26KB binary represents very high density. Static analysis tools that inspect only the IAT observe approximately 60 visible KERNEL32 functions. The 113 indirect call sites represent the hidden majority of actual OS capability -- network operations, registry access, cryptographic functions -- all resolved and called at runtime without static visibility. This architecture makes signature-based import scanning systematically incomplete for this sample.

F17 -- LoadLibraryA Reference: Single DATA Pointer

Result: 1 reference only -- DATA reference type, located in .data section. LoadLibraryA is not called directly from any code execution path. Its address is stored as a pointer and is called indirectly through one of the 113 FF 15 sites identified in F16. Consistent with a centralized function pointer dispatcher architecture.

F18 -- Complete IAT Structure: 60 KERNEL32 Functions

Method: Ghidra Listing navigation to 10008000 (IAT start). Section .rdata, range 10008000-10009bff. Contiguous pointer array, 4 bytes per entry.

```
Dynamic Loading:   100080d0 LoadLibraryA    10008070 GetProcAddress
Memory Mgmt:       10008010 VirtualAlloc    1000801c VirtualProtect    10008054
VirtualFree
File Operations:   10008004 CreateFileA     1000800c ReadFile          10008074
WriteFile
Anti-Analysis:     10008048 IsDebuggerPresent
TLS (threading):   10008080 TlsAlloc        1000807c TlsGetValue       10008084
TlsSetValue
Synchronization:   10008060 EnterCriticalSection    1000805c LeaveCriticalSection
```

The IAT is deliberately minimal yet complete for Stage 1 loader functionality. Network, registry, and cryptographic functions are entirely absent -- these reside in Stage 2. The presence of TLS and critical section primitives confirms multi-threaded architecture. String operation functions directly support the substitution table system documented in F12-F15.

F19 -- Dynamic Loading String Search: Negative Result

```
Searched: ws2_32, winhttp, wininet, ntdll, advapi32
Result: NONE FOUND
```

K7UI.dll is a pure Stage 1 loader with tightly bounded scope. No DLL names for dynamic loading, no function name strings for GetProcAddress resolution, no network library references. The separation of concerns is architectural and deliberate: Stage 1 loads Stage 2 from disk and transfers execution. Stage 2 carries all operational capability. AV and EDR tools scanning files at rest encounter a binary that appears to perform only file I/O and memory operations.

F8 -- No Visible C2 Configuration

No IP address, domain, or URL is present as a plaintext string in the binary. C2 configuration is entirely in Stage 2 (MpSvc.dll), loaded into memory at runtime and decrypted using the substitution table system (F4, F12-F15). Static analysis of Stage 1 alone is structurally incapable of recovering C2 information.

3.5 Entropy Analysis

F10 -- Overall Entropy: 6.14 / 8.0

Method: Python3 Shannon entropy calculation. Result: 6.1401536847751552 / 8.0. Scale 0-8, where 8.0 is fully random (encrypted). 6.14 indicates mixed content -- partially obfuscated sections coexist with sparse data sections. Consistent with a loader architecture where the code section is obfuscated (F11) but payload data is not embedded.

F11 -- Per-Section Entropy [PHIM]

Section	Entropy	Assessment
.text	6.5937	ANOMALOUS -- elevated for a code section (typical range: 5.0-5.5)
.rdata	5.1229	Normal
.data	2.2542	Very low -- mostly zeros / padding
.rsrc	4.8788	Normal
.reloc	4.5937	Normal

The .text entropy of 6.59 is a significant anomaly indicating code obfuscation or self-modifying logic within the execution path. The .data entropy of 2.25 confirms the Stage 2 payload is not embedded -- MpSvc.dll is loaded from disk separately. These entropy profiles have not been documented in prior FamousSparrow vendor reporting.

3.6 Section Structure

F9 -- Section Analysis

Section	Size	Offset	Flags
.text	26KB (0x6624)	0x400	CODE, READONLY
.rdata	7KB (0x1bd0)	0x6c00	DATA, READONLY
.data	3.5KB (0x0e00)	0x8800	DATA
.rsrc	436b (0x01b4)	0x9600	DATA, READONLY
.reloc	3KB (0x0c52)	0x9800	DATA, READONLY

The .rsrc section is near-empty at 436 bytes, containing no icon, version info, or meaningful resources. Deliberate: resource sections are a primary fingerprinting target for static analysis tools. Minimal .rsrc reduces the static signature surface. The .reloc section with approximately 150 fixups is high relative to binary size, consistent with position-independent code designed to execute at arbitrary memory addresses -- supporting the reflective loading mechanism in F7.

4. Architectural Summary

Based on F1-F20, the sample is a Stage 1 Loader Component. Its architecture is built around one objective: load Stage 2 from disk, inject it into memory, and transfer execution -- while remaining as invisible as possible to static analysis and automated sandbox environments.

Component	Role	Key Findings
Stage 1 (K7UI.dll)	Loader: masquerade, anti-sandbox, reflective inject MpSvc.dll	F1-F9, F11-F20
Stage 2 (MpSvc.dll)	Backdoor: C2, command execution, credential harvesting	External reporting only -- not analyzed

The separation of concerns is architectural and deliberate. Stage 1 presents a minimal import profile -- only KERNEL32.dll, no network or registry functions visible. The 113 indirect call sites mask the actual runtime call pattern. The .text section obfuscation prevents signature matching against the execution logic. The inverted anti-sandbox check defeats automated analysis. Stage 2 never appears on disk as a standalone file during execution.

Stage 2 capabilities from external reporting (UK NCSC, ESET): remote command execution, file upload/download, screenshot capture, keylogging, process management, file system change monitoring, C2 via HTTPS port 443, XOR encryption with key hH7@83#mi, configurable beaconing intervals.

5. Indicators of Compromise

5.1 File Indicators

Type	Indicator	Notes
SHA256	8dfaa1f579de14bca8bb27c54a57dd87646a835969766ca9ddb81ecd9329f4e4	K7UI.dll -- Stage 1 loader
File path	K7UI.dll	DLL sideloading target -- K7 Antivirus masquerade
Export functions	K7UI_1, K7UI_13	Falsified export table
String	MpSvc.dll	Stage 2 component reference
Exception code	0xc0000409	Anti-sandbox masquerade (STATUS_STACK_BUFFER_OVERRUN)
Cookie values	0xBB40E64E, 0x44BF19B1	Stack canary / encryption key candidates

5.2 Network Indicators (External Reporting)

Type	Indicator	Notes
IP	194.165.16.69	SparrowDoor C2 (ESET)
IP	198.12.75.112	SparrowDoor C2 (ESET)
Domain	cdn.kkxx888666[.]com	DRBControl overlap -- Metasploit C2 on FamousSparrow victim
Protocol	HTTPS port 443	C2 communication (UK NCSC)
XOR key	hH7@83#mi	Stage 2 C2 encryption key (UK NCSC)

5.3 Behavioral Indicators

Type	Indicator	Notes
Anti-sandbox [PHIM]	Terminates if IsDebuggerPresent == 0	Inverted logic -- F20
Substitution tables [PHIM]	.rdata pattern at 0x10008898, 0x10008ea1, 0x10009021	YARA candidate -- F12-F15
Indirect calls [PHIM]	113 FF 15 sites in .text, range 10001042-100070df	Anti-detection architecture -- F16

6. MITRE ATT&CK Mapping

ID	Technique	Observed
T1574.002	DLL Side-Loading	K7UI.dll masquerading as K7 Antivirus component
T1027	Obfuscated Files or Information	Substitution table obfuscation; .text entropy 6.59
T1055.001	Process Injection: DLL Injection	Reflective loading of MpSvc.dll into memory
T1562.001	Impair Defenses: Disable or Modify Tools	Inverted anti-sandbox logic via IsDebuggerPresent
T1140	Deobfuscate / Decode Files or Information	Runtime decryption via substitution tables
T1059.003	Command Interpreter: Windows Command Shell	Stage 2 remote command execution (external reporting)
T1071.001	Application Layer Protocol: Web Protocols	HTTPS C2 on port 443 (UK NCSC)
T1195.001	Supply Chain Compromise: Software Dependencies	ProxyLogon exploitation targeting Exchange (2021)

7. External Intelligence & Attribution

> *Attribution disclaimer: All attribution claims in this section are based on external vendor reporting. SerapHim analysis (F1-F20) makes no independent attribution -- scope is limited to the technical sample.*

7.1 Threat Actor Aliases

Alias	Source	Year
FamousSparrow	ESET	2021
Salt Typhoon	Microsoft	2024
UNC2286	Mandiant	Undisclosed
GhostEmperor	Kaspersky	2020-2021
Earth Estries	Trend Micro	2024

PRC affiliation is confirmed by FBI and CISA joint statements (2024). ESET (2025) and Microsoft (2024) disagree on whether FamousSparrow and GhostEmperor are the same actor or distinct groups with observed overlaps. This report treats them as the same actor consistent with the Microsoft assessment.

7.2 Campaign Timeline

Period	Activity
August 2019	First documented SparrowDoor deployment -- hotels worldwide
March 3, 2021	ProxyLogon exploitation begins -- one day after patch release (March 2, 2021)
2019-2022	Legacy SparrowDoor variant active -- hotel infrastructure focus
March 10, 2023	China brokers Saudi-Iran normalization (Beijing Agreement)
2023-present	Pivot to telecommunications and ISP targeting; modular variant deployed
November 2024	Trend Micro / Trustwave SpiderLabs disclosure
March 2025	ESET updated analysis -- two new modular variants documented
2024-2025	FBI / CISA joint advisory; WSJ reporting on US telecom breaches

7.3 SparrowDoor Variant Comparison

Attribute	Legacy (2019-2022)	Modular (2024-present)
Architecture	Single-stage loader	Multi-stage, plugin system
Command processing	Sequential	Parallel (concurrent execution)
Code quality	Basic	Improved -- marked progress per ESET
Sample analyzed	Yes -- this report	No -- not analyzed

The sample analyzed (8dfaa1f579...) corresponds to the legacy variant based on its single-stage loader architecture (F19), basic reflective loading mechanism (F7, F18), and absence of parallelization capability. The modular 2024 variant represents significant evolution.

7.4 SerapHim Findings vs External Reporting

Finding	SerapHim (F1-F20)	External Reporting	Status
DLL Sideloading	K7UI.dll masquerade confirmed (F2)	ESET: K7 AntiVirus abuse	Full match
MpSvc.dll Stage 2	String reference (F3)	UK NCSC: libcurl.dll + libhost.dll	Variant difference
Inverted anti-sandbox	Inverted IsDebuggerPresent (F20)	Not documented anywhere	[PHIM]
Substitution tables	Triplet normalization system (F12-F15)	Not documented anywhere	[PHIM]
Network capability	Absent from Stage 1 (F19)	UK NCSC: C2 in Stage 2	Consistent
.text entropy anomaly	6.59/8.0 (F11)	Not documented anywhere	[PHIM]
Indirect call density	113 FF 15 sites (F16)	Not documented anywhere	[PHIM]

8. Pivot Analysis

> *All pivot work conducted using passive open-source intelligence only. No active probing of infrastructure was performed.*

8.1 Sample Hash

The SHA256 8dfaa1f579de14bca8bb27c54a57dd87646a835969766ca9ddb81ecd9329f4e4 is sourced from the ESET malware-ioc GitHub repository. No occurrence was found in prior CTI reporting outside the ESET disclosure at time of analysis. VirusTotal historical data, first detection date, and vendor classification spread were not accessible at the analyst's access level -- deferred to future analysis with commercial platform access. The hash is now publicly documented in CTI-003 as a legacy variant (2019-2022) identifier.

8.2 C2 Infrastructure

Two C2 server IPs are documented in ESET malware-ioc: 194.165.16.69 and 198.12.75.112. ASN, hosting context, historical passive DNS, certificate metadata, and port scan history were not accessible at the analyst's access level (requires PassiveTotal, DomainTools, Shodan, or Censys paid access). The domain cdn.kkxx888666[.]com was observed as a Metasploit C2 on a FamousSparrow-compromised machine, attributed to the DRBControl group -- consistent with tool-sharing and contractor overlap patterns in external reporting.

8.3 K7UI Export Pattern as Tracking Artifact

The export naming pattern K7UI_[digit] is a YARA-suitable fingerprint. K7 Computing's market penetration is concentrated in India (primary), Southeast Asia, and a secondary MENA subset. It is not widely deployed in Europe, the Americas, or Africa. The victim clustering includes Saudi Arabia, Israel, Thailand -- within or adjacent to K7's market -- while France, UK, Lithuania, Brazil, and Canada are not K7 markets. The UK NCSC sample uses libcurl.dll and libhost.dll naming -- generic FOSS names with no regional identity. Hypothesis: FamousSparrow deploys region-adapted masquerade variants.

CONFIDENCE: *MODERATE -- K7 market penetration confirmed. Variant-specific deployment is inferred from naming and victim geography correlation.*

8.4 Substitution Table Byte Pattern (YARA Candidate)

The three-table sequence beginning at 0x10008898 is a candidate for a file-based YARA detection rule targeting the triplet pattern across FamousSparrow variants. Not documented in any prior public reporting -- would be a high-specificity signature if the same pattern appears in the 2024 modular variant. Cross-sample search requires access to a large malware database -- deferred to future analysis.

8.5 ProxyLogon +1 Day Exploitation Timeline

Date	Event
March 2, 2021	Microsoft releases ProxyLogon patches (CVE-2021-26855, -26857, -26858, -27065)
March 3, 2021	FamousSparrow begins ProxyLogon exploitation -- one day post-release

Hafnium had zero-day access before public disclosure. FamousSparrow was among the fastest post-disclosure actors, beginning exploitation within 24 hours of patch release. This suggests either advance knowledge of vulnerability details before public release, or a rapid exploit development capability of under 24 hours. If this pattern holds across multiple disclosures, it becomes a behavioral signature for FamousSparrow.

CONFIDENCE: *HIGH (timeline confirmed by ESET telemetry). MODERATE (advance knowledge hypothesis -- circumstantial).*

8.6 Pivot Summary and Tracking Artifacts

Artifact	Type	Tracking Value	Confidence
SHA256 8dfaa1f579...	Hash	Legacy variant (2019-2022) identification	HIGH
Export pattern K7UI_[digit]	Code signature	Masquerade fingerprint; YARA candidate	HIGH
Substitution table byte pattern	Code signature	Three-table sequence -- YARA candidate	HIGH
Exception code 0xc0000409	Behavioral	Anti-sandbox technique fingerprint	MODERATE
Indirect call density ~113	Metric	Obfuscation tooling fingerprint	MODERATE
MpSvc.dll string	Artifact	Asia/MENA variant hypothesis	MODERATE
ProxyLogon +1 day timeline	Behavioral	Intelligence access indicator	MODERATE

9. Geopolitical Strategic Assessment

> *This section constitutes strategic assessment, clearly separated from the technical findings above. All conclusions carry explicitly stated confidence levels and represent analytical judgment, not confirmed fact.*

9.1 What FamousSparrow Actually Is

FamousSparrow has been read in public reporting as a Chinese espionage operation targeting hotels and telecom infrastructure to collect diplomatic intelligence. That reading is accurate but incomplete. It describes what FamousSparrow collected. It does not describe what FamousSparrow is.

Read as a sequence rather than a static operation, FamousSparrow's targeting evolution -- hotels in MENA diplomatic zones (2019), Exchange servers via ProxyLogon (2021), US domestic ISPs and telecom providers (2023-2024) -- is a record of China's changing intelligence question. Each pivot reflects a new primary question that the previous targeting could no longer answer. The operation did not escalate in the conventional sense. It reassessed.

This report argues that FamousSparrow is not only a collection instrument. It is documentary evidence of how China's strategic assessment of the Middle East evolved -- from a theater that could be contested to one that had to be accepted as lost -- and of how China repositioned its collection apparatus for the scenario that follows.

The intelligence objective was not to know what was discussed in hotel rooms or on intercepted calls. It was to detect when the trajectory of US-Saudi-Israel normalization crossed from negotiable to irreversible -- the point at which China's only available disruption mechanism, Iran's proxy network, would no longer be able to change the structural outcome. Every diplomatic movement tracked was a data point on convergence speed. FamousSparrow made China an observer with enough advance warning to decide whether proxy disruption was still operationally viable. When the targeting moved to US domestic telecom, the question had already changed: not whether normalization could be stopped, but how the US would coordinate military power once MENA was settled.

CONFIDENCE: *HIGH (collection method confirmed). MODERATE (strategic reassessment argument -- inferred from targeting sequence, pivot timing, and structural outcomes in 9.3-9.7).*

9.2 Technical Findings -- Strategic Implications

F2 (K7 Masquerade) -> Asia/MENA-Specific Variant Hypothesis

K7 Computing's market is India, Southeast Asia, and a secondary MENA subset -- not Europe or the Americas. The UK NCSC-analyzed FamousSparrow sample uses generic library names (libcurl.dll, libhost.dll) with no regional identity. The K7UI export table falsification is not a universal choice -- it is a regionally plausible choice for environments where K7 is deployed. The hypothesis is that FamousSparrow maintains region-adapted variants: K7UI masquerade for Asia/MENA theater, generic FOSS naming for Western targets.

CONFIDENCE: *MODERATE -- K7 market penetration confirmed. Variant deployment inference is circumstantial.*

F1 (32-bit, Windows 5.00) -> Legacy Infrastructure Targeting

A 32-bit binary with Windows XP era compatibility header, deployed in 2019-2022, indicates intentional targeting of environments that retain legacy Windows infrastructure: hotel management and POS systems in secondary markets, government agencies in developing countries (Honduras, Guatemala, Burkina Faso are in the victim list), and engineering firms with older operational systems. 32-bit runs on all x64 systems via WOW64, but modern malware development for 64-bit environments exclusively is the norm. The choice maximizes compatibility across heterogeneous victim infrastructure age profiles.

CONFIDENCE: *MODERATE.*

F20 (Inverted Anti-Sandbox) -> PRC Development Tier Assessment

The inverted anti-sandbox technique is not documented in ESET, UK NCSC, Trend Micro, or Microsoft FamousSparrow reporting. It requires understanding of automated sandbox behavior -- specifically that sandboxes do not attach debuggers -- and deliberate inversion of the conventional anti-debug response. The use of exception code 0xc0000409 to masquerade the termination as a compiler security feature demonstrates additional engineering attention. This is either state-level R&D capability, deliberate dead code, or a time-pressure artifact. Hypothesis A is most probable given the masquerade engineering.

CONFIDENCE: *MODERATE (technique confirmed from disassembly). LOW (operational function -- hypotheses unresolved without dynamic analysis).*

F12-F15 (Substitution Table System) -> Development Resources

Using custom character tables instead of Windows API functions (lstrcmpiA, CompareStringA) for case-insensitive string operations is deliberate import-evasion engineering. It requires a developer with knowledge of import-based detection mechanisms. The tables are stored in .rdata (read-only), efficient, and purpose-built for C2 command normalization. FamousSparrow has access to either an experienced malware development team or a reusable code framework that implements this pattern.

CONFIDENCE: *MODERATE.*

9.3 Strategic Context: What the US Is Building -- and Why China Is Watching It

At the surface level, US policy signals since 2021 suggest strategic withdrawal from the Middle East: no more forever wars, Indo-Pacific pivot rhetoric, Biden's public Saudi recalibration. This is the wrong frame. The US was not withdrawing. It was substituting one form of presence for another -- more durable, less costly, and structurally more difficult for any external actor to obstruct.

What the US has been constructing is a normalization architecture: a self-sustaining regional coalition that does not require permanent US troop deployment to maintain regional order. The Abraham Accords (2020) were the structural blueprint. Israel functions as the military anchor. Saudi Arabia as the economic anchor. UAE as the financial and normalization hub. If Saudi-Israel normalization is completed, the coalition becomes self-reinforcing without direct US management. US provides security guarantees, technology transfers (F-35s, civil nuclear technology, defense pacts), and diplomatic cover -- but day-to-day regional order maintenance is handled by local partners at dramatically reduced operational cost.

This is what China has been watching through FamousSparrow. Not whether US troops are present. Whether the normalization architecture is close enough to operational to no longer be disruptable.

What China loses if the architecture completes:

- Malacca Dilemma -- CRITICAL: 80% of China's oil imports transit the Malacca Strait, effectively under US Navy influence. Iran plus overland BRI corridors constitute the structural answer to an energy blockade in a Taiwan conflict scenario. If normalization completes and Iran's regional influence collapses, the overland alternative closes. China becomes fully dependent on sea routes the US can interdict without firing a shot at Chinese territory.
- Taiwan Buffer -- CRITICAL: Iran's proxy network -- Houthi, Hezbollah, Hamas, Iraqi militias -- forces the US to maintain split strategic focus between MENA and Indo-Pacific simultaneously. A fully consolidated MENA under US-aligned coalition means the entire US military apparatus can be concentrated on a single theater. This changes the Taiwan Strait confrontation calculus fundamentally.
- Beijing Agreement Credibility -- HIGH: China brokered Saudi-Iran normalization in March 2023. If Iran collapses and Saudi Arabia pivots fully to the US-Israel axis, the Beijing Agreement becomes

retroactively meaningless. The message to every Global South government currently hedging between Washington and Beijing: China cannot protect the partners it mediates for.

- BRI Western Anchor -- HIGH: Iran is the western terminus of BRI's overland corridors through Central Asia and Pakistan. Without Iran as a stable anchor, the infrastructure investment chain is exposed to disruption by actors aligned with the normalization coalition.
- Energy Chokepoint Control -- MODERATE-HIGH: 20% of global oil and LNG supply transits the Strait of Hormuz. China needs to ensure no single opposing power controls Hormuz. That guarantee disappears with Iran's regional influence.
- Red Sea / Bab-el-Mandeb -- MODERATE: Iran's support for the Houthis gave China indirect influence near its only overseas military installation at Djibouti. Without that, Saudi-UAE-US control of Red Sea shipping is uncontested.
- Diplomatic Credibility -- MODERATE: The Beijing Agreement was China's most significant regional diplomatic achievement in a decade. Its retroactive failure signals to all prospective partners that Chinese mediation does not come with protection.

US escalation as normalization mechanism -- the primary conclusion:

Less than 48 hours before the February 28, 2026 strikes, US negotiators met with Iran's Foreign Minister in Geneva for a third round of Oman-mediated talks. Oman's Foreign Minister publicly announced substantial progress and a follow-up meeting scheduled for March 2. On the same day those talks concluded in Geneva, embassy evacuations from Tehran were already underway -- a fact not disclosed publicly until after strikes began. Trump stated he was not satisfied with Geneva results. The following day, strikes began.

Oman's Foreign Minister Al-Busaidi, after hostilities broke out, stated publicly that the war against Iran was an attempt to restructure the Middle East in the interest of Israel. This is the assessment of the mediator who operated in good faith until the moment strikes began. The Arms Control Association assessed independently that Trump had likely made the decision to go to war before the Geneva round concluded.

The structural outcome confirms the framing: Iran's leadership decapitation removes the only counterweight that gave Saudi Arabia reason to delay normalization indefinitely. CENTCOM is now planning a Combined Middle East Cyber Center -- command architecture for cyber, information warfare, and maritime operations -- built on the Abraham Accords coalition framework. The infrastructure is not being built before normalization completes. It is being built because the conditions for normalization to complete have now been forced into existence. US did not need to station permanent troops in the Middle East. It needed to remove the variable that made the coalition self-reinforcing without US direct management impossible. That variable was Iran.

CONFIDENCE: *MODERATE-HIGH (event sequencing confirmed by open source reporting). MODERATE (intent inference -- escalation as mechanism vs escalation as response).*

9.4 Timeline Correlation: Campaign Activity vs Diplomatic Events

Phase 1: Biden Policy Shift -> ProxyLogon Deployment

Date	Event	Intelligence Significance
January 20, 2021	Biden inaugurated	Policy reset anticipated
February 4, 2021	Biden announces Saudi 'recalibration'	Public pressure on MBS begins

February 25, 2021	Khashoggi report declassified	US-Saudi relationship publicly strained
February 26, 2021	US ends support for Yemen offensive	Further public distancing from Riyadh
March 2, 2021	ProxyLogon patch released	Exploitation opportunity opens
March 3, 2021	FamousSparrow exploitation begins	Infrastructure deployed within 24 hours

Intelligence question China needed answered: Is US-Saudi recalibration genuine policy, or public theater while private normalization talks with Israel continue? Public statements alone could not answer this. Hotel infrastructure in the diplomatic zones where private conversations were occurring could.

Phase 2: Infrastructure Pre-Positioning vs Diplomatic Activity

Event	Date	Days After Exploitation
ProxyLogon exploitation begins	March 3, 2021	0 (baseline)
Saudi FM statement on Israel normalization	March 22, 2021	+19 days
Blinken first Middle East trip	May 24-26, 2021	+82 days

Infrastructure was pre-positioned 82 days before the primary diplomatic target arrived in theater. This is real-time monitoring architecture, not post-visit artifact collection. Blinken's May 24-26 trip covered Gaza ceasefire consolidation, US-Israel ironclad commitment reaffirmation, and meetings with Netanyahu, Abbas, Sisi, and King Abdullah. A persistent hotel network compromise, deployed 82 days prior, captures pre-arrival planning communications, meeting schedules, and post-meeting debriefs transmitted over hotel Wi-Fi.

Phase 3: October 7 and the Disruption Window

By mid-2023, US-Saudi-Israel normalization talks were at their most advanced point since the Abraham Accords. FamousSparrow's collection through hotel and emerging telecom infrastructure was producing signals of exactly this convergence.

The October 7, 2023 Hamas attack collapsed the normalization track immediately. This report does not assert that China ordered or caused the attack. The observable outcome alignment is noted: the attack achieved the specific outcome most useful to both China and Iran simultaneously -- normalization halted, US-Saudi momentum broken, diplomatic focus absorbed into Gaza conflict management for over twelve months. The absence of a direct evidentiary link does not make the correlation analytically insignificant. It makes it a hypothesis that cannot be closed.

CONFIDENCE: *HIGH (timing correlations confirmed). MODERATE (intelligence intent and October 7 alignment -- correlation-based, not causal).*

Geographic Progression: Shadowing US Diplomatic Engagement Zones

Period	Primary Theater	Pattern
2019-2020	Global dispersed (hotels worldwide)	Broad surveillance baseline -- establishing infrastructure across diplomatic transit nodes
2021-2022	MENA (Israel, Saudi Arabia) + Latin America	Dual-region concentration -- mirrors US diplomatic engagement zones
2023-2024	United States domestic telecom infrastructure	MENA disappears from public reporting -- full pivot to US-domestic collection

MENA disappearance from 2023-2024 reporting admits three hypotheses: (A) October 7 temporarily satisfied the disruption window requirement -- normalization collapsed, collection priority reduced, resources reallocated; (B) MENA infrastructure was detected and burned, forced pivot; (C) selective reporting bias -- MENA targeting continues but unreported. Available data does not discriminate between these hypotheses.

9.4b The Pivot as Acceptance: FamousSparrow as a Map of Chinese Strategic Reassessment

The 2023 pivot from MENA hotel infrastructure to US domestic telecom providers is not an escalation of the same operation. It is a strategic pivot that implies China had reached a specific conclusion: the Middle East as a theater for preventing the normalization architecture is no longer winnable.

China cannot permanently prevent Saudi Arabia from choosing alignment with Israel and the US. The proxy disruption mechanism -- Iran's network -- can delay normalization but cannot reverse the structural incentives that make it attractive to Riyadh. October 7 bought time. It did not change the calculus. By mid-2023, China's intelligence collection from FamousSparrow would have been sufficient to assess that normalization was on a long-term trajectory regardless of disruption attempts.

The targeting sequence maps to a strategic reassessment:

Period	Targeting	Primary Intelligence Question
2019-2022	Hotels in MENA diplomatic zones	How fast is normalization progressing? Is proxy disruption still viable?
2021	ProxyLogon -- Exchange servers	What is the US communicating privately to regional partners that does not appear in public statements?
2023-2024	US domestic ISPs and telecom providers	How will the US coordinate military response when a Taiwan Strait crisis occurs?

US domestic telecom infrastructure has no utility for monitoring Saudi-Israel normalization. It has direct utility for one purpose: understanding the command, control, and communication architecture of a US military response to a large-scale conflict in the Indo-Pacific. The shift in targeting is a shift in the primary threat scenario China is preparing to understand -- from a MENA disruption operation to a Taiwan Strait pre-positioning operation.

FamousSparrow began as the sensor layer that made Iran's proxy disruption operationally informed rather than blind. It ended as the sensor layer for a scenario in which Iran is no longer a participant.

CONFIDENCE: *MODERATE (pivot timing and targeting confirmed). MODERATE (strategic intent -- inferred from targeting sequence and structural outcomes).*

9.5 China-Iran Intelligence Sharing Framework

The 25-Year China-Iran Strategic Partnership, formalized in 2021, established a documented intelligence cooperation framework. China provides Iran cyber-espionage tools, data collection capabilities, raw intelligence to identify and disable Western assets, satellite SIGINT from China's 500+ satellite constellation, and BeiDou navigation system access at military-grade encrypted level.

The Silent Axis report (June 2025) documented that China offered significant support to Iran in dismantling the US intelligence network on Iranian territory, providing technological tools and potentially raw intelligence to identify and disable American intelligence assets. Modern Diplomacy reporting

(January 2026) documented that in July 2025, Iran was cooperating with China to investigate how Israel had penetrated Iranian databases.

In the context of FamousSparrow: intelligence collected through hotel and telecom infrastructure in the US-Saudi-Israel diplomatic theater flows through this framework to Iran, enabling Iran's proxy network to apply disruption at the point of maximum normalization momentum. China possesses global SIGINT reach, Iran possesses regional HUMINT networks in Iraq, Syria, and Lebanon.

CONFIDENCE: *MODERATE-HIGH (intelligence sharing framework confirmed by multiple sources). MODERATE (specific intelligence products shared -- inferred, not directly observed).*

9.6 FamousSparrow and Dust Specter: Complementary Operations

Operation	Operator	Target	Collected	Shared With
FamousSparrow	PRC	Hotels, telecom -- US-Saudi-Israel zones	Normalization progress, diplomatic patterns	-> Iran
Dust Specter	Iran (LOW-MOD)	Iraqi MFA	Iraqi diplomatic shifts, US-Iraq coordination	-> China (hypothesized)

The division of labor is structurally coherent with the capabilities of each actor. FamousSparrow monitors the macro-level diplomatic convergence. Dust Specter monitors the regional tactical signals -- specifically Iraq as an early warning indicator for realignment away from Iran. Together, the two operations constitute a layered surveillance architecture covering both the strategic trajectory (normalization) and the regional tactical signals (Iraqi diplomatic shifts) that would precede any military action against Iran.

Both operations failed to prevent strategic surprise for Iran on February 28, 2026. The precision targeting of Iran's intelligence leadership in the opening strike -- killing the Deputy Minister for Israeli Affairs, the head of the Espionage Division, and the Deputy for Internal Security -- indicates that the US and Israel had current, precise location data. An intelligence apparatus that had successfully monitored for the threat would not have its entire senior leadership killed in the first hours.

CONFIDENCE: *MODERATE-HIGH (intelligence sharing framework confirmed). MODERATE (complementary operation design -- inferred from timing, targeting, and strategic logic).*

9.7 Operation Outcome Assessment and Closing Thesis

Outcome Assessment

Event	Date	Significance
US-Israel coordinated strikes on Iran	February 28, 2026	Supreme Leader killed. Senior intelligence leadership killed in opening wave.
Precision targeting of intelligence leadership	February 28, 2026	First-wave precision indicates current location data. Iranian intelligence apparatus operationally blinded.
Thomas Barrack-Al-Sudani Baghdad meeting	November 2025	US warned Iraq of impending strike. Iraqi forces subsequently shot down Iranian drones near Baghdad Airport on February 28.
Oman FM Geneva statement	February 27, 2026	Announced substantial progress in Iran nuclear talks, follow-up scheduled March 2. Strikes began the following day.

Iraq's active role in the February 28 strikes against Iran-aligned assets is the observable outcome of exactly the diplomatic shift Dust Specter was designed to detect early. Dust Specter did not detect it in time to be actionable. FamousSparrow MENA and Dust Specter Iraq, together, failed to prevent strategic surprise. Assessment: MIXED for China. Tactical collection was likely successful across both operations' lifespans. Strategic outcome -- Iran leadership decapitated, normalization architecture unobstructed, Taiwan buffer eliminated.

Closing Thesis

The February 28 outcome does not represent the failure of China's intelligence strategy. It represents the completion of the phase that strategy was designed for -- and the confirmation that the next phase, already underway, is the more consequential one.

FamousSparrow MENA was built to answer whether normalization could be stopped. The answer, delivered by the structural outcome of February 28, is that it could not. That answer was already embedded in the 2023 telecom pivot -- China's targeting behavior changed before the final confirmation arrived externally. The pivot is evidence that China's intelligence apparatus reached its own conclusion about MENA's trajectory before February 28 made it externally observable.

The strategic question China is now positioned to answer -- through infrastructure embedded in US domestic telecommunications -- is not about the Middle East at all. It is about what comes after the Middle East is settled: the timing, coordination, and response architecture of the US military in the next confrontation. Whether that confrontation arrives in the Taiwan Strait, the South China Sea, or in some configuration not yet visible in current reporting, the collection infrastructure FamousSparrow built into US telecom networks will be more relevant to that scenario than any intelligence produced by monitoring hotel corridors in Riyadh.

The 26KB DLL analyzed in this report is an artifact from the beginning of that trajectory. It was built to watch a diplomatic process in a region that is now, structurally, under the architecture it was designed to obstruct. What it reveals about China's capabilities, evasion techniques, and development sophistication is documented in F1-F20. What it reveals about where China's collection is now directed requires reading the pivot, not the sample.

CONFIDENCE: *MODERATE (outcome facts confirmed by open source reporting). MODERATE (closing thesis -- inferred from targeting sequence, structural outcomes, and geopolitical context. Not confirmed fact).*

10. Analysis Limitations

This report is produced with full transparency regarding analytical boundaries. The limitations below are structural constraints that any reader applying this report to operational or policy decisions must understand.

Limitation	Detail
Dynamic analysis incomplete	Stage 2 (MpSvc.dll) was not analyzed. All Stage 2 capability data is sourced from UK NCSC and ESET external reporting.
F17 address pending confirmation	The exact address for the LoadLibraryA DATA reference was not fully captured before the analysis session ended.
China-Iran intelligence	The framework is confirmed by multiple sources. That specific FamousSparrow

sharing -- products not directly observed	intelligence products were shared with Iranian decision-makers is inferred from targeting patterns and strategic logic, not recovered intelligence products.
Geopolitical assessment is retrospective and correlation-based	Section 9 connects technical artifacts to geopolitical outcomes that occurred after the sample was deployed. Causal confirmation is not possible from open-source analysis.

The conclusions in this report should be understood as the floor of what occurred, not the ceiling.

11. Defensive Recommendations

#	Recommendation
1	DLL sideloading monitoring: alert on K7 Antivirus component names (K7UI.dll, K7UI_1, K7UI_13) loaded from non-standard paths or outside K7 installation directories.
2	IAT scanning limitation: supplement import-table-based detection with behavioral monitoring. Static IAT scanning surfaces only 60 KERNEL32 functions, missing 113 indirect call sites. Behavioral EDR that observes runtime API calls will detect the full footprint.
3	Sandbox evasion: samples terminating immediately with STATUS_STACK_BUFFER_OVERRUN (0xc0000409) on startup should not be classified as non-functional. Re-analyze with a debugger attached -- SparrowDoor's inverted logic runs normally under debugger attachment.
4	YARA detection: the three-table substitution byte sequence in .rdata (beginning 0x10008898) is a candidate for a file-based YARA rule with high specificity across FamousSparrow variants.
5	Network monitoring: alert on HTTPS connections to non-approved external destinations from hotel management systems, POS systems, Oracle Opera installations, and legacy Windows infrastructure.
6	Secrets hygiene: do not store API keys, SSH private keys, or plaintext credentials in filesystem locations accessible from development tooling or hotel Wi-Fi networks.
7	ProxyLogon behavioral pattern: monitor for FamousSparrow activity within 24-48 hours of future high-priority CVE patch releases -- particularly for Microsoft Exchange or SharePoint.
8	US telecom context: organizations in US telecommunications, ISP, and critical communications infrastructure should treat Salt Typhoon / FamousSparrow intrusion indicators as active, not historical. The 2023-2024 pivot to domestic telecom is confirmed by FBI and CISA joint advisory and assessed as ongoing.

12. References

[1] ESET Research. FamousSparrow: A suspicious hotel guest. September 2021.
[2] ESET Research. Updated FamousSparrow analysis -- two new SparrowDoor variants. March 2025.
[3] UK NCSC. Malware Analysis Report: SparrowDoor. February 2022.
[4] Trend Micro. Earth Estries campaign analysis. November 2024.
[5] Trustwave SpiderLabs. FamousSparrow / Salt Typhoon report. December 2024.
[6] Microsoft. Salt Typhoon threat actor profile. 2024.
[7] FBI / CISA. Joint advisory on Salt Typhoon / FamousSparrow telecom breaches. 2024.
[8] Wall Street Journal. Salt Typhoon breached multiple US telecommunications providers. September 2024.
[9] Help Net Security. FamousSparrow 2025 activity update. March 2025.

[10] The Silent Axis. China-Iran intelligence cooperation framework. June 2025.

[11] Modern Diplomacy. China-Iran cooperation to investigate Israeli database penetration. January 2026.

[12] Reuters. US and Israel strike Iran; Supreme Leader Khamenei killed. February 28, 2026.

[13] AP News. US envoy Barrack warns Iraq of Israeli strikes on Iran-aligned militias. November 2025.

[14] Arms Control Association. US-Iran Geneva negotiations and February 28 strike timeline analysis. March 2026.

[15] CBS Face the Nation. Oman FM Badr Al-Busaidi -- Geneva talks and post-strike statement. February 27 / March 2026.

[16] ECPS / Prof. Ibrahim Ozturk. The deliberately segmented crisis: conflict, energy, and great power rivalry post-Iran strike. March 2026.

[17] CENTCOM. Combined Middle East Cyber Center planning. 2026.

[18] MITRE ATT&CK. FamousSparrow (G1101). attack.mitre.org.

[19] ESET malware-ioc. FamousSparrow sample repository. github.com/eset/malware-ioc/famoussparrow.

[20] SerapHim. CTI-002: Dust Specter -- State-Sponsored OSINT Operation Targeting Iraqi Diplomatic Infrastructure. March 10, 2026.

TLP:CLEAR. This report may be shared freely without restriction. All network indicators have been defanged.
SerapHim, Independent Cyber Threat Intelligence, March 2026.